

基於 UN R155 規範之車載 Wi-Fi 資安測試框架 與威脅建模研究

A Threat-Modeling-Based Wi-Fi Security Testing Framework for
In-Vehicle Networks under UN Regulation No. 155

撰寫人：丁時揚、陳玕嶧、李宥寬

指導教授：許富皓教授

執行機構：國立中央大學資訊工程學系

研究單位：財團法人車輛研究測試中心（ARTC）

執行期間：115 年 01 月 01 日至 115 年 11 月 30 日

摘要

車聯網 (Internet of Vehicles, IoV) 與車載資通訊單元 (T-Box) 的普及，使 Wi-Fi 成為車輛對外連線的重要介面之一，同時也擴大了未授權存取、惡意熱點誘騙、管理框架干擾與弱認證等攻擊面。UN R155 與 ISO/SAE 21434 進一步要求車廠建立涵蓋風險評估、驗證測試與證據留存的資安管理系統 (CSMS)，但業界目前仍缺乏針對車載環境 (低延遲、高移動性、多為嵌入式作業系統) 量身打造的自動化 Wi-Fi 資安測試腳本與標準化驗證流程，測試人員往往須手動切換多個命令列工具，導致操作不一致、結果難以追溯。

本研究以 ARTC 車聯網測試場域為對象，建立一套以威脅建模為核心的車載 Wi-Fi 資安測試框架，並實作對應之 Web 化可視化測試平台。首先將 T-Box 的無線運作情境區分為「AP 模式」與「Client / Station 模式」兩類，分別界定其攻擊面：AP 模式聚焦於安全組態缺陷 (WPS 啟用、弱加密、缺乏管理訊框保護、缺乏用戶端隔離)；Client / Station 模式則聚焦於偽造熱點誘騙、連線阻斷服務與異常握手封包注入，並進一步將 Deauthentication 與 Evil Twin 二項攻擊技術串接為具因果關係的「Deauth—Evil Twin 整合攻擊鏈」，用以檢驗 PMF (802.11w)、WPA3 / 802.1X 伺服器端驗證與用戶端組態三道防線的有效性。

系統以 Flask 與 Socket.IO 建立前後端架構，後端整合無線掃描、安全組態稽核、授權攻擊情境執行、無線入侵偵測 (WIDS) 與 JSONL 稽核紀錄五大模組；當缺少實體測試工具或監聽模式硬體時，系統自動切換為模擬輸出，以支援開發、教學與展示，並於論文中明確區分模擬結果與實體測試結果。WIDS 模組並實作「Deauth 突發流量後隨即出現相同 SSID、不同 BSSID 新 AP」之高信度關聯規則，作為 Evil Twin 攻擊之核心判定依據。

目前成果以功能原型、威脅模型與流程驗證為主；實體 T-Box 測試、量化偵測準確率與效能數據仍待於 ARTC 授權實驗環境中補充。

關鍵詞：車聯網、車載 Wi-Fi 資安、威脅建模、WIDS、Deauthentication、Evil Twin、滲透測試、UN R155、ISO/SAE 21434

Abstract

The growing use of Wi-Fi as an external connectivity interface for the in-vehicle Telematics Box (T-Box) has expanded the attack surface of connected vehicles, exposing them to unauthorized access, rogue-AP deception, management-frame interference, and weak-authentication attacks. UN Regulation No. 155 and ISO/SAE 21434 require manufacturers to operate a Cyber Security Management System (CSMS) that covers risk assessment, verification testing, and traceable evidence, yet the industry still lacks automated, vehicle-specific Wi-Fi security test scripts and a standardized verification workflow suited to the low-latency, high-mobility, embedded nature of in-vehicle systems.

This study proposes a threat-modeling-driven Wi-Fi security testing framework for in-vehicle networks, targeting the ARTC connected-vehicle testbed, together with a Web-based visualized testing platform. The T-Box’s wireless operating context is first divided into an *AP mode* and a *Client/Station mode*, each with a distinct attack surface: AP mode centers on configuration weaknesses (WPS enabled, weak encryption, missing PMF, missing client isolation), while Client/Station mode centers on rogue-AP deception, connection denial-of-service, and abnormal handshake injection. A *Deauth–Evil Twin attack chain* is further constructed by chaining deauthentication and Evil Twin techniques into a causally linked scenario used to evaluate three defense layers: PMF (802.11w), WPA3/802.1X server-side certificate validation, and client-side configuration.

The platform is built on Flask and Socket.IO, integrating wireless scanning, security configuration auditing, authorized attack-scenario execution, wireless intrusion detection (WIDS), and JSONL-based audit logging. A simulation fallback is provided when physical tools or monitor-mode hardware are unavailable, and simulated results are explicitly separated from physical-hardware results throughout the thesis. The WIDS module implements a high-confidence correlation rule — a burst of deauthentication frames immediately followed by a new AP sharing the same SSID but a different BSSID — as the primary criterion for Evil Twin detection.

Current results consist of a functional prototype, a threat model, and workflow validation; physical T-Box testing, quantitative detection accuracy, and performance data remain to be collected in an authorized ARTC test environment.

目錄

1	緒論	1
1.1	研究背景與動機	1
1.2	問題陳述	1
1.3	研究目的與貢獻	1
1.4	研究範圍與限制	2
1.5	論文組織	2
2	文獻探討與相關研究	3
2.1	車聯網與 T-Box 資安架構	3
2.2	車輛網路安全法規與標準	3
2.3	IEEE 802.11 安全機制	3
2.4	無線網路攻擊手法分析	4
2.5	現有車載資安測試與防護技術之侷限	4
2.6	相關工具與技術基礎	5
3	威脅建模與系統架構	6
3.1	測試目標與環境定義	6
3.2	威脅模型	6
3.2.1	AP 模式之攻擊面	6
3.2.2	Client / Station 模式之攻擊面	7
3.3	測試平台與 WIDS 系統架構設計	7
3.3.1	系統整體架構	7
3.3.2	模組化設計理念	8
3.3.3	AP / Client 雙模式測試流程	8
4	研究方法與核心實作	9
4.1	使用情境與角色	9
4.2	功能需求	9
4.3	開發環境與系統技術棧	9
4.4	自動化合規與組態檢測實作	10

4.5	主動攻擊模擬腳本實作	10
4.6	無線入侵偵測模組 (WIDS) 開發	11
4.7	稽核紀錄與即時通訊	12
4.8	可視化測試平台介面設計	12
4.9	安全與風險控制	12
5	實驗設計與成效評估	13
5.1	實驗環境與設備建置	13
5.2	實驗情境設計	13
5.2.1	情境一：AP 模式下的合規性防護壓力測試	13
5.2.2	情境二：Client 模式下的動態誘騙與阻斷攻擊測試	13
5.2.3	實驗案例與觀測指標	16
5.3	評估指標	16
5.4	實驗結果與分析	16
6	討論	17
6.1	研究成果對 UN R155 合規性之貢獻	17
6.2	研究成果與需求對照	17
6.3	測試框架之侷限性與挑戰	17
6.4	合規與實務應用意義	17
7	結論與未來工作	18
7.1	研究總結	18
7.2	未來工作	18
A	API 與日誌欄位	21
A.1	REST API 一覽	21
A.2	Socket.IO 事件	21
A.3	JSONL 稽核紀錄欄位定義	21

表目錄

3.1	AP 模式攻擊面與對應威脅	6
4.1	系統功能需求與對應實作	9
4.2	授權攻擊情境與對應工具	10
5.1	實驗環境設定表	13
5.2	Deauth-Evil Twin 攻擊鏈判定準則	14
5.3	三道防線與其作用環節	15
5.4	實驗案例與觀測指標	16
A.1	系統 REST API 端點	21
A.2	logs/testing.jsonl 欄位定義	22

第 1 章 緒論

1.1 研究背景與動機

車聯網 (V2X) 的發展使車輛從封閉式電子系統逐漸轉變為具備遠端連線能力的行動終端，車載資通訊單元 (Telematics Box, T-Box) 則是銜接車內網路與外部通訊 (行動網路、Wi-Fi、藍牙) 的核心元件。T-Box 常見的 Wi-Fi 應用情境包含：作為 AP 提供車內娛樂系統或乘客裝置連線，以及作為 Client / Station 連接維修廠內網、公共熱點或原廠 OTA 更新伺服器。這兩種角色分別暴露出不同的攻擊面，也是本研究進行威脅建模的出發點。

國際法規面，UN R155 要求車輛型式認證須具備資安管理系統 (CSMS)，涵蓋風險評估、緩解措施與持續監控 [15]；ISO/SAE 21434 則提供威脅分析與風險評估 (TARA) 方法論作為工程實務依循 [7]。兩者皆強調「可驗證、可追溯」的測試證據，而非僅止於文件化的風險陳述。對車廠與測試機構而言，如何在有限人力下建立可重複執行、具證據力的 Wi-Fi 資安測試流程，是合規落地的實務挑戰。

1.2 問題陳述

車載 Wi-Fi 通訊在開放電磁環境下面臨若干具體威脅：其一為惡意熱點 (Rogue AP / Evil Twin)，攻擊者複製合法 SSID 並以更強訊號誘導車機自動連線；其二為中間人攻擊 (MITM)，一旦車機誤連至攻擊者控制的熱點，憑證竊取與惡意 OTA 導向即成為可能。然而，目前業界的資安測試工具多沿用一般 IT 網路的弱點掃描邏輯，並未考量車載環境「低延遲、高移動性、多為資源受限之嵌入式系統」的特性，也缺乏針對 Wi-Fi 專屬攻擊面 (PMF、WPS、Client Isolation 等) 的自動化測試腳本與標準化驗證流程。測試人員必須在多個命令列工具 (iw、aircrack-ng、reaver、hostapd 等) 間手動切換，操作步驟與判讀標準因人而異，結果也分散在不同終端機輸出中，難以形成可供稽核的合規證據。

1.3 研究目的與貢獻

本研究之具體目的與貢獻如下：

1. 建立針對 T-Box Wi-Fi 介面之**威脅分類模型**，以「AP 模式」與「Client / Station 模式」界定攻擊面，並提出具因果關係的 Deauth—Evil Twin 整合攻擊鏈作為代表性測試情境。
2. 開發**自動化資安測試腳本與無線入侵偵測模組 (WIDS)**，將 WPS、WPA3 / 802.1X、PMF、SSID 廣播、用戶端隔離等安全要求轉換為可重複執行的檢查項目與偵測規則。
3. 建構**可視化測試與合規驗證平台**，以集中式 Web 介面整合掃描、稽核、攻擊測試與 WIDS 監控，並提供具時間戳、分類與 JSONL 格式的稽核軌跡。
4. 以授權測試情境於 ARTC 測試場域驗證車聯網 Wi-Fi 防護能力，為 UN R155 / ISO-SAE 21434 所要求之驗證測試證據提供原型工具。

1.4 研究範圍與限制

本研究對象為 ARTC T-Box 測試台、實驗室 AP 與明確授權的無線目標，聚焦於 IEEE 802.11 Wi-Fi 層及其與車載測試流程的介面，不涵蓋完整車內 CAN 匯流排或車載乙太網路之漏洞分析，惟於第七章討論由 Wi-Fi 端點延伸至車內網路之後續研究方向。現階段部分模組在缺少 Kali / Parrot 測試工具或監聽模式硬體時採用模擬資料，論文之實驗章節將分開呈現模擬結果與實體結果，不以模擬輸出作為實體網路效能之結論。所有攻擊情境僅能於書面授權、電磁隔離（屏蔽箱 / 電波暗室）之環境中執行。

1.5 論文組織

本論文共分為七章：第一章為緒論，說明研究背景、問題陳述與研究目的；第二章回顧車聯網資安、802.11 安全機制與相關文獻；第三章提出威脅模型與系統整體架構；第四章說明研究方法與各模組之核心實作；第五章描述實驗設計與成效評估方法；第六章討論研究成果之合規意義與限制；第七章總結研究成果並提出未來工作方向。

第 2 章 文獻探討與相關研究

2.1 車聯網與 T-Box 資安架構

T-Box 一般整合行動網路數據機、GNSS 定位、CAN / 車載以太網路介面與短程無線通訊 (Wi-Fi、藍牙) 於單一嵌入式系統中，並透過閘道與車內其他 ECU 連通。短程無線介面因具備使用者可及性與相對開放的協定堆疊，成為研究人員與攻擊者皆容易切入的測試點；相較於需要專用診斷設備的 CAN 匯流排，Wi-Fi 攻擊面的重現成本更低、攻擊工具鏈也更成熟 (見 2.4 節)，因此適合作為車載資安測試自動化的優先對象 [10]。

2.2 車輛網路安全法規與標準

UN R155 要求車廠建立資安管理系統，涵蓋供應鏈風險管理、威脅監控、事件應變與型式認證後之持續驗證，並於 Annex 5 提供威脅與緩解措施的參考清單 [15]。ISO/SAE 21434 則提供工程層級的威脅分析與風險評估 (TARA) 方法論，定義資產、損害情境、攻擊路徑與風險等級之對應關係 [7, 19]。兩者在實務落地上的共同挑戰在於：風險評估文件需要具體、可重複的測試證據支撐，而非僅憑經驗判斷，這也是本研究建立自動化測試與稽核紀錄機制的主要動機之一。

2.3 IEEE 802.11 安全機制

本研究涉及之 802.11 安全機制包括：WPA2 個人 / 企業模式、WPA3-SAE (Simultaneous Authentication of Equals)、802.1X 企業驗證、WPS (Wi-Fi Protected Setup)、管理訊框保護 (Protected Management Frames, PMF / IEEE 802.11w)、SSID 廣播策略，以及用戶端隔離 (Client Isolation) [6]。其中 WPS PIN 機制因設計缺陷長期存在暴力破解風險；PMF 透過加密管理訊框 (如 deauthentication、disassociation) 防止偽造斷線攻擊，是抵禦本研究攻擊鏈的第一道防線；WPA3-SAE 雖以 Dragonfly 交換取代 WPA2 的 4-way handshake 以降低離線字典攻擊風險，但仍被證實存在旁通道與降級攻擊等實作層級弱點 [17]，WPA2 之 4-way handshake 亦曾被證實存在金鑰重裝攻擊 (KRACK) [16]，凸顯「協定設計安全」與「實作正確性」須同時檢驗的必要

性，此亦為本研究於稽核模組中同時檢查加密機制與 PMF 狀態，而非僅檢查加密演算法名稱的原因。

2.4 無線網路攻擊手法分析

車載資安領域的經典研究已證實，攻擊者可經由車輛對外介面取得車內網路的存取能力，包括透過蜂巢式網路、藍牙與 Wi-Fi 等管道進行遠端滲透，並進一步影響行車安全相關 ECU[3, 8, 12]。在 Wi-Fi 層級，常見攻擊手法包括：

- **Deauthentication / Disassociation 攻擊**：偽造管理訊框迫使目標裝置斷線，常作為其他攻擊之前置手段。
- **Rogue AP / Evil Twin**：複製合法 SSID 並以更强訊號建立偽造熱點，誘導裝置自動連線以進行 MITM，此類攻擊之偵測長年倚賴用戶端側時序或訊號特徵比對 [5]，近年並發展出完整之攻擊變異分類與 Kill Chain 模型 [1]。
- **WPS PIN 暴力破解**：利用 WPS 8 碼 PIN 可拆解驗證之設計缺陷，將原本 10^8 種組合之搜尋空間降至約 11,000 次嘗試即可窮舉，繞過強加密取得 PSK[18]。
- **握手封包擷取與離線破解**：擷取 4-way handshake 後於本地進行字典或 GPU 加速破解。

本論文於第三章將 Deauthentication 與 Evil Twin 兩項技術串接為具因果關係的攻擊鏈，用以模擬「先製造斷線、再誘導誤連」之真實威脅路徑，而非孤立評估單一攻擊手法 [2]。

2.5 現有車載資安測試與防護技術之侷限

現行 IT 弱點掃描工具（如通用漏洞掃描器）多以主機、服務或已知 CVE 為導向，缺乏對 802.11 管理訊框層級行為（PMF、握手序列、Rogue AP 關聯性）的專屬檢測邏輯，亦未考量車載場域「測試視窗短、目標裝置行動性高」之限制。業界對車載資安測試之討論多聚焦於流程與合規要求本身 [9, 4]；即便學術界已提出將車載資安測試自動化之方法論 [11]，其討論多集中於車輛網路（如 CAN 匯流排）與整體測試流程之自動化框架設計，較少提供可直接落地執行、針對 Wi-Fi 攻擊面之開源自動化腳本與可視化平台。本研究之定位即在於填補「合規要求」與「可執行測試工具」之間的落差。

2.6 相關工具與技術基礎

系統實作採用 Flask 作為 REST API 框架、Socket.IO 提供即時雙向通訊；無線掃描與稽核倚賴 iw；攻擊情境執行整合 wifite2（自動化稽核）、aircrack-ng 套件之 aireplay-ng（deauth）、reaver（WPS 暴力破解）與 hostapd（Rogue AP / Evil Twin 架設）；WIDS 模組則以 Scapy 進行封包層級的管理訊框監聽與特徵擷取。各工具之角色分工詳見第四章實作說明。

第 3 章 威脅建模與系統架構

3.1 測試目標與環境定義

本研究之測試目標為 ARTC 車聯網測試場域內之 T-Box 測試台與實驗室 AP，測試環境要求為電磁隔離之屏蔽箱或電波暗室，避免測試訊號干擾場域外之無線網路，並確保攻擊情境（deauth、Rogue AP）之影響範圍可控。所有測試前須完成書面授權確認，明確界定受測 BSSID / SSID、測試時間窗與測試人員權責，並於測試紀錄中保留授權依據，以符合 UN R155 對測試證據可追溯性之要求。

3.2 威脅模型

本研究依 T-Box 於 Wi-Fi 層之角色，將攻擊面區分為「AP 模式」與「Client / Station 模式」兩類，分別對應系統實作中的兩個處理階段（見 3.3 節），並以此作為攻擊情境與檢測邏輯設計之依據。

3.2.1 AP 模式之攻擊面

當 T-Box 作為 AP（例如提供車內娛樂系統或乘客裝置連線）時，攻擊面主要來自安全組態層級的缺陷，而非協定本身的漏洞：

Table 3.1: AP 模式攻擊面與對應威脅

攻擊面	威脅情境	對應防護
WPS 啟用 弱加密 / 認證	PIN 暴力破解繞過強加密 離線字典攻擊、金鑰重裝 (KRACK)	停用 WPS WPA3-SAE 或 802.1X
缺乏管理訊框保護 缺乏用戶端隔離 SSID 廣播不當	偽造 deauth / disassoc 迫使斷線 已連線裝置間橫向移動 目標識別、隱藏 SSID 之偽安全假象	PMF (802.11w) required 啟用 Client Isolation 依風險評估決定廣播策略

3.2.2 Client / Station 模式之攻擊面

當 T-Box 作為 Client / Station (例如連接維修廠內網、公共熱點或 OTA 伺服器) 時，攻擊面轉為「誘導裝置主動誤連」與「阻斷既有連線」：偽造 AP 誘騙 (Rogue AP / Evil Twin)、連線阻斷服務 (Deauth flood) 與異常握手封包注入。此三者中，Deauthentication 與 Evil Twin 具備明確的前後因果關係，構成本研究之核心測試情境：

攻擊者先架設一個複製目標 SSID、訊號強度更高的 Evil Twin 熱點；再對已連線之 T-Box 注入 Deauth 訊框迫使其斷線；T-Box 於重新搜尋網路時，若僅依 SSID 名稱自動連線，即可能誤連至攻擊者控制的 Evil Twin，進而遭受中間人攻擊、憑證竊取或惡意 OTA 導向。

此攻擊鏈之詳細測試流程、判定準則與三道防線對應關係，於第五章 5.2 節以完整實驗情境呈現。

3.3 測試平台與 WIDS 系統架構設計

3.3.1 系統整體架構

系統由瀏覽器端可視化平台、Flask + Socket.IO 後端，以及五個功能模組組成：無線掃描 (scan.py)、安全組態稽核 (config_audit.py)、攻擊工作管理器 (attack_runner.py)、WIDS 監控器 (wids.py) 與 JSONL 稽核紀錄器 (logger.py)。瀏覽器透過 REST API 發出控制請求 (啟動掃描、稽核、攻擊工作、WIDS)，並透過 Socket.IO 接收工作狀態 (job_update)、即時輸出 (job_output) 與 WIDS 事件 (wids_event)，圖 3.1 為系統整體架構示意。

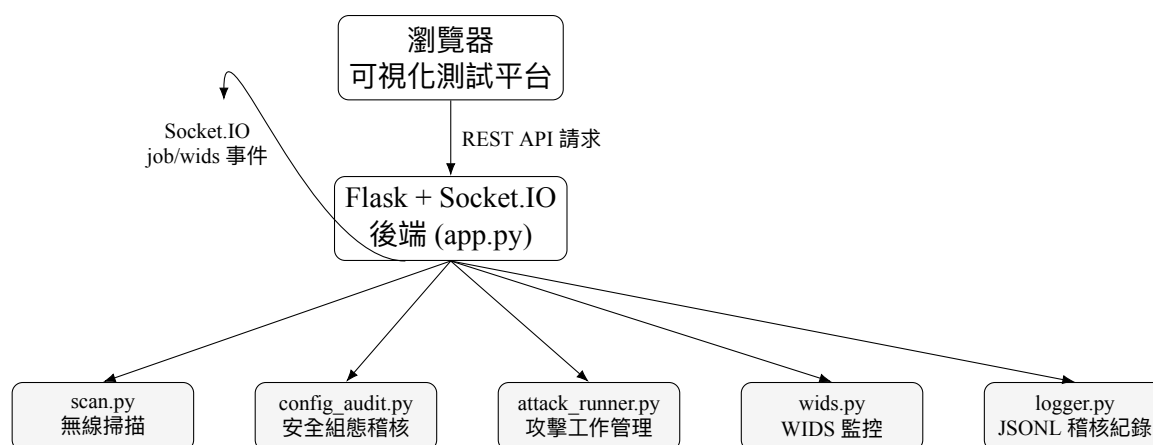


Figure 3.1: 系統整體架構：瀏覽器、Flask 後端與五大功能模組

3.3.2 模組化設計理念

五個後端模組依功能可歸納為三類：

1. **合規檢測模組**：scan.py 與 config_audit.py，負責被動掃描與 WPS / 加密 / PMF / SSID 廣播等組態稽核。
2. **攻擊模擬模組**：attack_runner.py，以工作(job)為單位管理 wifite2、aireplay-ng、reaver、hostapd 等外部工具之啟動、即時輸出串流與停止。
3. **異常偵測模組**：wids.py，以 Scapy 監聽管理訊框，實作滑動時間窗計數與 Rogue AP 關聯規則；logger.py 則橫向支援前三者，將所有事件統一寫入 JSONL 稽核軌跡。

此模組化設計使合規檢測、攻擊模擬與異常偵測三者可獨立開發、獨立測試，亦便於日後替換或新增底層工具（例如以 hcxdumpool 取代 aircrack-ng 套件之握手擷取功能）而不影響上層 API 與前端介面。

3.3.3 AP / Client 雙模式測試流程

承 3.2 節之威脅模型，前端可視化平台將完整測試流程劃分為兩個模式、四個階段，並以流水線（pipeline）形式依序呈現：

AP 模式

- (a) **安全組態檢測**：被動掃描選定目標 AP，執行 WPS / WPA3-802.1X / SSID 廣播稽核。
- (b) **進階防護技術檢測**：檢查 PMF（802.11w）與用戶端隔離，並可搭配主動 PMF 探測情境。

Client / Station 模式

- (a) **主動防禦與異常偵測**：啟動 WIDS 於固定時間窗內監聽並回報異常事件。
- (b) **攻擊模擬與驗證**：執行 Deauth、Rogue AP 等授權攻擊情境並彙整完整日誌。

此設計使測試工程師可依受測 T-Box 當下角色（AP 或 Client）選擇對應的測試路徑，避免將兩種攻擊面之檢測項目混雜於單一流程中。

第 4 章 研究方法與核心實作

4.1 使用情境與角色

測試工程師負責選擇無線介面、掃描目標並執行測試情境；資安分析人員檢視 WIDS 事件與稽核紀錄，判斷是否觸發告警；審查人員則取得具時間戳與分類之測試證據，用於內部合規審查或對外呈現 UN R155 驗證結果。

4.2 功能需求

Table 4.1: 系統功能需求與對應實作

編號	功能需求	對應實作
F-01	列出可用無線介面	modules/scan.py
F-02	掃描 BSSID、SSID、頻道、訊號與加密	scan_networks()
F-03	稽核 WPS、強認證、PMF、SSID 與用戶端隔離	config_audit.py
F-04	執行並停止授權測試工作	attack_runner.py
F-05	即時傳送工作輸出與狀態	Socket.IO
F-06	啟動與停止 WIDS 監控	wids.py
F-07	保存測試事件與結果	logger.py

4.3 開發環境與系統技術棧

後端以 Python 3 撰寫，採用 Flask 提供 REST API、Flask-SocketIO(async_mode="threading") 提供即時通訊；前端為原生 HTML / CSS / JavaScript，透過 socket.io 用戶端函式庫與後端通訊，不依賴額外前端框架，以降低部署複雜度。攻擊情境執行之作業系統、無線網卡型號、監聽模式設定與各工具版本，待於 ARTC 實體測試環境確認後於 5.1 節實驗環境表補齊。

4.4 自動化合規與組態檢測實作

`config_audit.py` 之 `audit_target()` 以 `scan_networks()` 之被動掃描結果為輸入，比對目標 BSSID 後依序執行五項檢查，並以 PASS / FAIL / WARN / INFO / MANUAL 五種狀態表示結果：

1. **WPS 停用檢查**：若信標中偵測到 WPS 資訊元素則判定 FAIL，否則 PASS。
2. **WPA3 / 802.1X 驗證邏輯**：加密欄位為 WPA3 時判定 PASS；為 OPEN 或 WPA 時判定 FAIL；其餘情形（如僅偵測到 RSN 但未能區分 WPA2 / WPA3）則判定 WARN，提示應升級至 WPA3 或 802.1X，避免二元判定掩蓋中間風險等級。
3. **PMF (802.11w) 強制啟用檢測演算法**：讀取 RSN Capabilities 中之 MFPR (Management Frame Protection Required) / MFPC (Capable) 位元，區分「required (PASS)」、「capable (WARN，可選但未強制)」與「未偵測到 (FAIL)」三級，對應第三章威脅模型中 PMF 作為第一道防線之判定依據。
4. **SSID 廣播管控與隱藏 SSID 探測**：當掃描結果之 SSID 欄位為空或為預設之 `<hidden>` 標記時，判定為隱藏 SSID 並提示此僅為「安全假象 (security-by-obscurity)」而非有效控制，而非直接判定為缺失，避免常規工具在隱藏 SSID 情境下無法導出有效名稱、進而誤判之問題。
5. **用戶端隔離**：標記為 MANUAL，因被動掃描無法確認同一 AP 下兩個已連線用戶端之間是否可互相通訊，須另以主動 Layer 2 探測（例如 ARP 請求）驗證是否仍可觀察到其他用戶端之 ARP 流量或遭受 ARP 詐騙 [13]，避免以被動掃描結果做出過度自信的判定。

稽核結果彙整為 FAIL / WARN 統計摘要 (summary)，供前端與稽核紀錄快速呈現整體風險等級。

4.5 主動攻擊模擬腳本實作

`attack_runner.py` 以情境 (scenario) 為單位，將六種授權測試情境定義為命令樣板，於執行時以 `params` 填入必要參數：

Table 4.2: 授權攻擊情境與對應工具

情境代碼	說明	底層命令樣板
------	----	--------

wifite_auto	wifite2 全自動稽核（握手 擷取與破解）	wifite --bssid {bssid} --channel {channel} -i {interface} --kill
handshake_cap	僅擷取 4-way handshake， 不進行破解	wifite ... --no-crack --no-wps
deauth	Deauth flood，驗證 PMF / 802.11w 防護	aireplay-ng --deauth {count} -a {bssid} {interface}
wps_bruteforce	Reaver WPS PIN 暴力破 解	reaver -i {interface} -b {bssid} -c {channel}
rogue_ap	架設 Evil Twin (hostapd)	hostapd {config_path}
pmf_probe	送出偽造管理訊框，觀 測 PMF 拒絕行為	python3 scripts/pmf_probe.py --iface {interface} --bssid {bssid}

工作管理器（AttackRunner）以 job_id 追蹤每個工作，狀態機為 pending → running → finished / killed / error；啟動時以獨立執行緒(threading.Thread)執行子行程，逐行讀取 stdout 並經 Socket.IO 以 job_output 即時串流至前端，結束後以 job_update 回報最終狀態與 return code。當目標底層工具（如 wifite、aireplay-ng）未安裝於執行環境時，系統自動切換為**模擬模式**，輸出預先定義之階段性訊息（監聽模式切換、掃描、封包擷取進度），使前端串流管線與工作生命週期可在無實體工具的開發機上完整驗證，並於稽核紀錄中明確標記為模擬輸出。

4.6 無線入侵偵測模組（WIDS）開發

wids.py 於偵測到 Scapy 可用時，以 sniff() 於監聽模式介面上擷取管理訊框；若 Scapy 或監聽模式硬體不可用，則退回模擬事件迴圈，兩者共用相同的事件輸出格式（ts、type、message、severity、iface），確保前端事件面板行為一致。

大量重傳與偵測邏輯：目前已實作之 Deauth flood 偵測，以滑動 5 秒時間窗計數 Dot11Deauth 訊框數量，若時間窗內累積超過 20 個訊框，即觸發 deauth_flood 高嚴重度事件。此設計與既有 802.11 WIDS 文獻中以 deauth 訊框發送速率、訊框大小與訊框間隔作為特徵之簽章式偵測方法一致 [14]；門檻值本身則為初始設定，尚待第五章實體測試以統計正常網路之背景雜訊率後校準。

惡意熱點辨識演算法：對應第三章之高信度關聯規則——偵測到 Deauth 突發流量後，若隨即出現「相同 SSID、不同 BSSID」之新 AP，即判定為 Evil Twin 高度可疑特徵並觸發告警；若僅偵測到其一則記錄為一般異常事件。相較於既有研究多採用用戶端側之 DNS 往返時間量測 [5] 判斷是否連上 Rogue AP，本研究之偵測邏輯部署於 WIDS（監聽端）而非受測 T-Box 端，優點是不須修改車機軟體即可監控，但亦因此無法得知車機實際是否已連線至偽造熱點，須與 5.2 節之 Step 5 主動觀測結果

交叉比對方能完整判定。此關聯訊號較單獨偵測 Deauth 或 Rogue AP 更具因果證據力，亦是 5.2 節攻擊鏈實驗之核心判定依據。beacon flood、握手異常（如 M2 未先於 M1 出現）等偵測項目目前於模擬迴圈中以合成事件呈現，實體 Scapy 偵測邏輯之特徵擷取仍待第七章未來工作補強。

4.7 稽核紀錄與即時通訊

`logger.py(TestLogger)`將所有模組事件以 JSON Lines 格式寫入 `logs/testing.jsonl`，每筆紀錄包含 `ts` (Unix 時間戳)、`level` (INFO / WARN / ERROR)、`category` (`scan` / `audit` / `attack` / `wids`) 與 `message` 四個欄位，並以固定長度雙端佇列 (`deque`，預設 2000 筆) 快取於記憶體中，供 `/api/logs` 快速回傳最近事件而不需每次讀檔。JSONL 格式便於後續以行為單位串流處理或匯入其他分析工具，亦符合 UN R155 對測試證據應可追溯、逐筆記錄之精神。Socket.IO 事件則涵蓋 `job_update` (工作狀態變化)、`job_output` (工作即時輸出) 與 `wids_event` (WIDS 告警)，三者皆廣播至所有已連線之前端用戶端。

4.8 可視化測試平台介面設計

前端提供兩種檢視模式：**經典儀表板** (`index.html`) 以分頁呈現「掃描」「組態稽核」「攻擊情境」「WIDS 監控」「日誌」五個功能區塊，供測試人員逐項操作；**流程檢視** (`flow.html`) 則將 3.3.3 節所述之 AP / Client 雙模式流水線以卡片式介面呈現，依序執行「AP 模式：安全組態檢測 → 進階防護技術檢測」與「Client / Station 模式：WIDS 監聽 → 攻擊模擬與驗證」四個階段，並以進度條與即時日誌串流面板呈現整體執行狀態，使審查人員可於單一畫面掌握完整測試流程與各階段之 PASS / FAIL 結果，此即第五章 5.1 節所稱之「可視化測試平台介面」。

4.9 安全與風險控制

正式部署前須補上身分驗證與角色型權限控管 (測試工程師 / 分析人員 / 審查人員三種角色之權限應予區隔)、命令參數驗證 (避免使用者輸入之 BSSID、介面名稱等參數被用於命令注入)、測試範圍限制 (強制檢查目標是否列於授權清單)、日誌防竄改 (如簽章或僅附加寫入) 與敏感資料遮罩。所有測試操作必須於隔離網段內、依書面授權之目標執行，此為本平台由原型邁向正式合規工具前之必要前提。

第5章 實驗設計與成效評估

5.1 實驗環境與設備建置

Table 5.1: 實驗環境設定表

項目	設定	待填資料
測試平台	ARTC T-Box / 實驗室 AP	型號、韌體版本
測試主機	Kali / Parrot / 其他	CPU、記憶體、OS
無線介面	監聽模式網卡	晶片、驅動、介面名稱
測試工具	iw、wifite2、aircrack-ng、 reaver、Scapy	版本
測試場域	RF 隔離環境（屏蔽箱 / 電波 暗室）	場域編號、電磁隔離規格
網路設定	測試 SSID、頻道、加密方式	去識別化資料

5.2 實驗情境設計

依第三章威脅模型，實驗分為兩個情境，分別對應 AP 模式與 Client / Station 模式之攻擊面。

5.2.1 情境一：AP 模式下的合規性防護壓力測試

以實驗室 AP 或 T-Box AP 模式為對象，依序執行被動掃描、組態稽核，並以 WPS 暴力破解與握手擷取驗證「WPS 停用」與「強認證」兩項防護是否於壓力測試下維持有效。

5.2.2 情境二：Client 模式下的動態誘騙與阻斷攻擊測試

以 T-Box Client / Station 模式（連接維修廠內網或公共熱點情境）為對象，執行 4.4 節所述之 Deauth—Evil Twin 整合攻擊鏈，測試流程如下：

- Step 1 環境偵察與基線建立：**將網卡切換至 Monitor Mode，鎖定目標 AP 之 BSSID、T-Box 端 Client MAC 及運作通道；確認 T-Box 已完成 4-way handshake、處於正常連線狀態，記錄訊號強度與連線參數作為基線。
- Step 2 擷取 PMF 狀態：**自 AP 之 Beacon / Association Response 擷取 RSN Capabilities 欄位，判讀 PMF 為「不支援 / Capable（可選） / Required（強制）」，作為預期結果之依據。
- Step 3 架設 Evil Twin 釣魚熱點：**複製目標 SSID，以更強訊號建立釣魚熱點；視測試需要設定為開放式或偽造加密，用以驗證 T-Box 端是否進行伺服器端憑證驗證。
- Step 4 注入 Deauth 訊框：**對目標 Client 發送解除認證訊框，分兩種模式執行——定量模式（發送固定數量，如 100 幀，用於精確重現與比對）與連續模式（持續注入，模擬真實 DoS 壓力情境）。
- Step 5 觀測 T-Box 反應與重連行為：**監控 T-Box 是否斷線，以及斷線後的重連對象——是否因 PMF 生效而未斷線，或斷線後自動關聯至 Evil Twin，抑或因憑證驗證失敗而拒絕連線。
- Step 6 WIDS 偵測驗證：**確認 4.5 節所述偵測模組能否於滑動時間窗內辨識 Deauth 突發流量，並比對來源 MAC 是否為「未完成握手卻發出 Deauth」之偽造來源；同時執行 Evil Twin 高信度關聯偵測。
- Step 7 日誌記錄與結果判定：**匯出全程封包與偵測 LOG，於可視化平台以 Pass / Fail 標示，並保留詳細技術細節供稽核。

圖 5.1 為此攻擊鏈之流程示意，判定準則彙整於表 5.2，三道防線與其作用環節則彙整於表 5.3。

Table 5.2: Deauth–Evil Twin 攻擊鏈判定準則

結果	條件	資安意義
PASS	PMF (802.11w) 阻擋 Deauth 使 T-Box 未斷線；或雖斷線但因 WPA3 / 802.1X 憑證驗證失敗而拒連 Evil Twin	攻擊鏈於起點或導向環節即被中斷
FAIL	T-Box 遭成功斷線並自動關聯至 Evil Twin	存在被強制斷線並導向惡意伺服器之風險，須補強 802.11w 與伺服器端驗證
WIDS PASS	偵測模組成功告警並匯出日誌	具備主動偵測與稽核能量

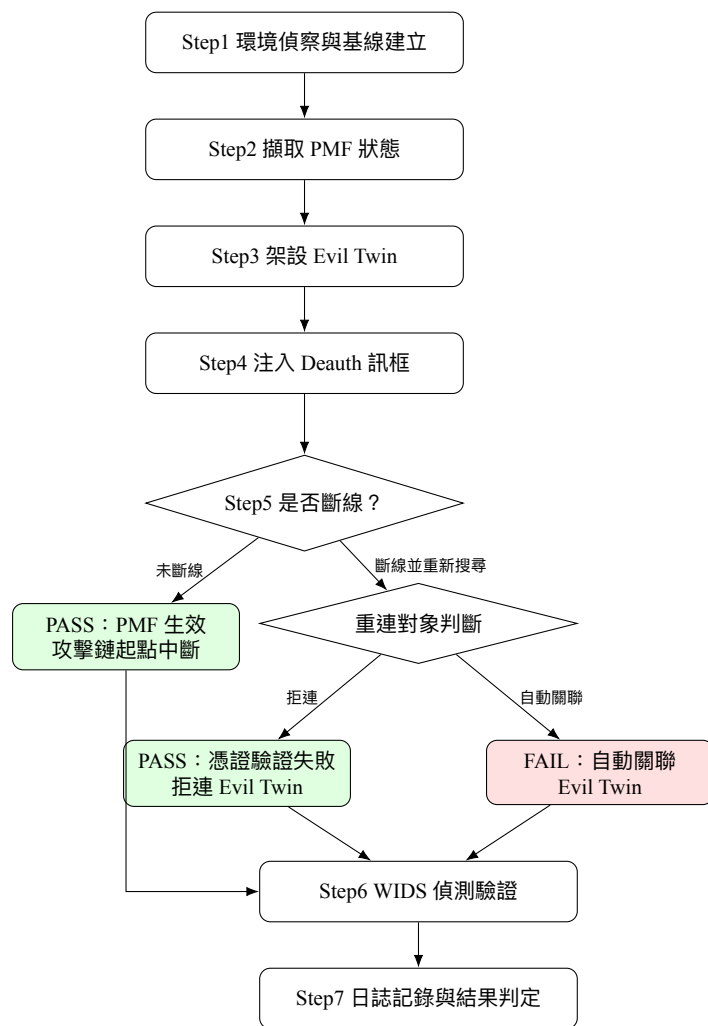


Figure 5.1: Deauth—Evil Twin 整合攻擊鏈測試流程

Table 5.3: 三道防線與其作用環節

防線	機制	作用環節
第一道	PMF (802.11w)	攻擊鏈起點阻擋 Deauth，使 T-Box 根本不被斷線
第二道	WPA3 / 802.1X 伺服器端驗證	Evil Twin 無法提供合法憑證而遭拒（最主要之防禦）
第三道	Client 端組態	避免僅憑 SSID 名稱自動加入未知網路

Table 5.4: 實驗案例與觀測指標

案例	目的	主要觀測結果
E-01	被動掃描 (情境一)	發現數、解析正確率、耗時
E-02	組態稽核 (情境一)	PASS / FAIL / WARN 一致性
E-03	PMF / Deauth (情境二 Step 1-5)	事件數、偵測延遲、連線影響
E-04	Rogue AP / Evil Twin 關聯 (情境二 Step 3-6)	告警正確性、誤報
E-05	握手流程 (情境一 / 二共用)	成功率、耗時、紀錄完整性
E-06	稽核追溯 (情境一 / 二共用)	時間戳、分類、工作 ID 關聯

5.2.3 實驗案例與觀測指標

5.3 評估指標

評估面向包含：功能正確性、WIDS 偵測延遲（攻擊發生至可視化平台告警之時間差）、偵測召回率與精確率、Evil Twin 關聯規則之誤報率、掃描耗時、API 回應時間、同時工作數、資源使用量，以及合規性驗證結果——即 T-Box 於遭受攻擊時，PMF 與 Client Isolation 成功阻擋威脅之數據證明（對應表 5.2 之 PASS 比例）與稽核紀錄完整性。

5.4 實驗結果與分析

待填入實體測試表格、統計圖、封包或日誌截圖，並依表 5.2、5.3 之準則彙整各案例之 PASS / FAIL / WIDS PASS 結果。分析時必須分別標示真實硬體結果與模擬資料，不得以 4.4 節所述之模擬輸出作為實體網路效能結論。

第 6 章 討論

6.1 研究成果對 UN R155 合規性之貢獻

本平台將 UN R155 所要求之「風險評估—驗證測試—證據留存」流程具體化為可重複執行的軟體工具：第三章之威脅模型對應風險評估階段，第四章之自動化稽核與攻擊情境對應驗證測試階段，第四章 4.6 節之 JSONL 稽核紀錄則對應證據留存階段，三者串接成一條可追溯的合規證據鏈，可作為車廠或測試機構準備型式認證資料之原型工具。

6.2 研究成果與需求對照

逐項回應第一章之研究目的：威脅分類模型見第三章 3.2 節；自動化測試腳本與 WIDS 見第四章 4.4–4.6 節；可視化平台見第四章 4.8 節；授權測試驗證見第五章實驗設計，惟量化結果仍待補充。

6.3 測試框架之侷限性與挑戰

現階段限制包括：外部工具輸出尚未完整結構化（例如 wifite2 之輸出仍以原始文字串流呈現，未解析為結構化欄位）；WIDS 多數事件仍為骨架或模擬輸出，beacon flood 與握手異常偵測器尚待實作；系統尚未具備角色型身分驗證、正式報告匯出與日誌防竄改機制。此外，在極高頻寬流量下是否存在封包遺失導致偵測漏報之問題，以及框架對未公開零日漏洞之偵測能力，皆屬本方法論之固有限制，須於未來工作中以壓力測試與定期規則更新機制因應。

6.4 合規與實務應用意義

本平台可作為 UN R155 / ISO-SAE 21434 測試證據產生工具的原型，但仍需由組織流程、供應鏈風險分析、權限控管與正式審查補足完整合規要求；平台本身僅能證明「特定測試情境下之技術防護有效性」，無法取代組織層級之資安管理制度。

第 7 章 結論與未來工作

7.1 研究總結

本研究以威脅建模為核心，針對 T-Box 之 AP 與 Client / Station 兩種 Wi-Fi 運作模式界定攻擊面，並以此為基礎完成一套整合掃描、組態稽核、授權攻擊測試、WIDS 監控與稽核紀錄之 Web 化車載 Wi-Fi 資安測試平台原型；並提出具因果關係之 Deauth-Evil Twin 整合攻擊鏈與對應之三道防線判定準則，作為驗證 PMF、WPA3 / 802.1X 與用戶端組態防護有效性之具體測試情境。正式結論待完成實體測試後，加入量化數據與限制條件。

7.2 未來工作

1. 完成 wifite2、封包擷取檔與測試結果的結構化解析，取代目前之原始文字輸出。
2. 補充 DragonBlood[17]、KRACK[16] 等已知降級與旁通道攻擊之測試腳本，以及真實 deauth reason-code 分類。
3. 完成 beacon flood、握手異常及 Rogue AP 的 Scapy 偵測器，並以實體測試數據校準 WIDS 門檻值（如 5 秒時間窗之 deauth 計數閾值）。
4. 加入角色型身分驗證、權限控管與安全命令參數驗證，強化測試範圍限制。
5. 建立 PDF / UN R155 證據包匯出與報告模板，並實作日誌防竄改機制。
6. 於 ARTC T-Box 測試台進行多版本韌體、多種加密設定與重複樣本驗證，補齊第五章之量化實驗結果。
7. 整合長程無線（Cellular / 5G）與其他短程無線（藍牙）之檢測，並探討由 Wi-Fi 端點突破後，針對車內 CAN 匯流排進行防護與阻斷之整合性研究。

參考文獻

- [1] Piotr Augustyniak and Piotr Zwierzykowski. Evil twin attack in wi-fi networks: Evolution, mutation taxonomy, and exposure time analysis (2005–2026). *Electronics*, 15(15):3432, 2026.
- [2] S. Boumiza and R. Braham. Intrusion threats and security solutions for autonomous vehicle networks. In *2017 IEEE/ACS 14th International Conference on Computer Systems and Applications*, pages 120–127, Hammamet, Tunisia, 2017.
- [3] S. Checkoway, D. McCoy, B. Kantor, D. Anderson, H. Shacham, S. Savage, K. Koscher, A. Czeskis, F. Roesner, and T. Kohno. Comprehensive experimental analyses of automotive attack surfaces. In *Proceedings of the USENIX Security Symposium*, San Francisco, CA, 2011.
- [4] Dennemeyer. Software solutions for automotive: Cybersecurity in mobility, 2025.
- [5] Hao Han, Bo Sheng, Chiu C. Tan, Qun Li, and Sanglu Lu. A timing-based scheme for rogue ap detection. *IEEE Transactions on Parallel and Distributed Systems*, 22(11):1912–1925, 2011.
- [6] IEEE Standards Association. Ieee 802.11 wireless lan standard, 2020. 使用版本與 PMF 條文待確認.
- [7] International Organization for Standardization and SAE International. Iso/sae 21434:2021 road vehicles – cybersecurity engineering, 2021.
- [8] K. Koscher, A. Czeskis, F. Roesner, S. Patel, T. Kohno, S. Checkoway, D. McCoy, B. Kantor, D. Anderson, H. Shacham, and S. Savage. Experimental security analysis of a modern automobile. In *2010 IEEE Symposium on Security and Privacy*, pages 447–462. IEEE Computer Society, 2010.
- [9] Feng Luo, Xuan Zhang, Zhenyu Yang, Yifan Jiang, Jiajia Wang, Mingzhi Wu, and Wanqiang Feng. Cybersecurity testing for automotive domain: A survey. *Sensors*, 22(23):9211, 2022.

- [10] Chao Ma, Hao Zhao, and Tong Wang. Research on cyber security risk of telematics box in intelligent connected vehicle. *MATEC Web of Conferences*, 355:03030, 2022.
- [11] Stefan Marksteiner and Zhendong Ma. Approaching the automation of cyber security testing of connected vehicles. In *Proceedings of the Third Central European Cybersecurity Conference (CECC 2019)*. ACM, 2019.
- [12] C. Miller and C. Valasek. Remote exploitation of an unaltered passenger vehicle. Black Hat USA, 2015.
- [13] Timur Mirzoev and Stacey White. The role of client isolation in protecting wi-fi users from arp spoofing attacks. *i-managers Journal on Information Technology*, 1(2), 2012. Also available as arXiv:1404.2172.
- [14] Sibi Chakkaravarthy Sethuraman, Sangeetha Dhamodaran, and Vaidehi Vijayakumar. Intrusion detection system for detecting wireless attacks in ieee 802.11 networks. *IET Networks*, 8(4):219–232, 2019.
- [15] United Nations Economic Commission for Europe. Un regulation no. 155: Uniform provisions concerning the approval of vehicles with regards to cyber security and cyber security management system, 2021. Annex 5.
- [16] Mathy Vanhoef and Frank Piessens. Key reinstallation attacks: Forcing nonce reuse in wpa2. In *Proceedings of the 2017 ACM SIGSAC Conference on Computer and Communications Security (CCS)*, pages 1313–1328, 2017.
- [17] Mathy Vanhoef and Eyal Ronen. Dragonblood: Analyzing the dragonfly handshake of wpa3 and eap-pwd. In *2020 IEEE Symposium on Security and Privacy (SP)*, pages 517–533. IEEE, 2020.
- [18] Stefan Viehböck. Brute forcing wi-fi protected setup: When poor design meets poor implementation, 2011. Whitepaper, 26 December 2011.
- [19] 中華電信研究院. 車聯網軟體更新國際標準：iso 21434 簡介, 2022.

第 A 章 API 與日誌欄位

A.1 REST API 一覽

Table A.1: 系統 REST API 端點

方法	路徑	說明
GET	/api/interfaces	列出主機上可用之無線介面
POST	/api/scan	被動掃描鄰近 AP (interface、duration)
POST	/api/audit	對指定 bssid 執行基線安全組態稽核
POST	/api/attack/start	啟動指定攻擊情境 (scenario、params)，回傳 job_id
POST	/api/attack/stop	依 job_id 停止執行中之攻擊工作
GET	/api/attack/jobs	列出所有攻擊工作及其狀態
POST	/api/wids/start	啟動 WIDS 監控 (interface)
POST	/api/wids/stop	停止 WIDS 監控
GET	/api/logs	取得最近 limit 筆稽核紀錄

A.2 Socket.IO 事件

- job_update：攻擊工作狀態變化(job_id、scenario、cmd、status、started_at、ended_at、return_code)。
- job_output：攻擊工作即時輸出 (job_id、line)。
- wids_event：WIDS 告警事件 (ts、type、message、severity、iface)。

A.3 JSONL 稽核紀錄欄位定義

Table A.2: logs/testing.jsonl 欄位定義

欄位	說明
ts	Unix 時間戳 (秒, 浮點數)
level	事件等級: INFO / WARN / ERROR
category	事件分類: scan / audit / attack / wids
message	事件內容描述

此附錄待補: 測試授權確認表、實驗截圖, 以及正式報告匯出格式 (PDF / UN R155 證據包) 之欄位規劃。